# (Assignment no. 2)

Name :- M. AHMED ABBAS

Reg no :- FA23-BCS-152

Submitted to :- Mr Salman Khan

Section :- BCS - 6 C

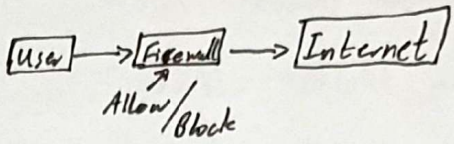
CamScanner

# Question no. 1

## a) OSI Model Mapping :-

Firewall :- Works on Network Layer (Layer 3). It filters IP addresses.

- Example: Block Unknown IP

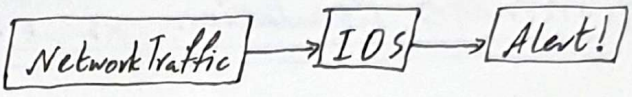



Encryption :- Works on Presentation Layer (Layer 6). It converts data into secret form.

- Example: HTTPs

IDS :- Works on Network and Application Layer (Layer 3 & 7). It detects attacks.

- Example: Detect hacking attempt.




## b) Zero-Day Attack :-

A Zero-Day Attack uses unknown vulnerabilities.

Risks :-

- Data Theft
- System damage
- No early protection

# Question no. 2

## a) SYN vs UDP Scan :-

| SYN Scan | UDP Scan |
|---|---|
| 1) Uses TCP | 1) Uses UDP |
| 2) Sends SYN packet | 2) Sends UDP packet |
| 3) Fast and hard to detect | 3) Slow and much easier to detect. |
| Attacker → SYN → Server<br>← SYN-ACK (open) | Attacker → UDP Packet → Server<br>(No reply = Open) |

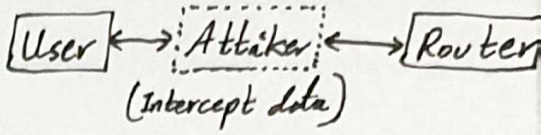
CamScanner

Reason :- TCP is connection-based, UDP is connectionless.

## b) Man-in-the-Middle (MitM) attack :-

Steps :-

1) Attacker sends fake ARP messages.
2) Victim thinks attacker is Router.
3) Data passes through Attacker.
4) Attacker reads or changes data.




## (Question no. 3)

## a) Privilege Escalation vs Insider Treat :-

Privilege Escalation :- It is gaining higher access illegally.

Insider Threat :- Threat from insiders like employees and people you trust.

**Examples :-**

Malicious :- Employee steals data.

Negligent :- User clicks the phishing link.

Compromised :- Hacker uses the employee account.

## b) SQL Injection :-

SQL injection means inserting SQL code in input fields.

**Example :-** " ' OR 1=1 -- "

Blind SQL Injection :-

1) No direct result shown.
2) Attacker guess response.
3) Hard to detect.

CamScanner

## Question no. 4

### a) Firewall Limitations :-

- Cannot inspect encrypted traffic
- Not suitable for dynamic cloud systems.

### b) Antivirus vs EDR :-

Antivirus :- It dectects known viruses.

EDR :- It is more advance, dectects behaviour and advanced threats

### c) Encryption vs Tokenization :-

Encryption :- Converts data into unreadable form. It makes Communication Secure. Data → [Encypt] → Secret Data

Tokenization :- Replaces data with tokens. It is used for Credit Card protection etc. Card no → Token(xxxx)

## Question no. 5

### a) Cloud Models :-

IaaS :- User controls OS and apps.

PaaS :- Platform provided.

SaaS :- Ready to use software.

### b) IaaS Threats :-

- Misconfiguration
- Data leakage.

Shared Responsibilities :-

**Provider** :- Hardware security

**User** :- Data and application security.

CamScanner

c) IAM (Identity & ~~Theft~~ Access Managament) :-

MFA :- Extra Security layer.

Least Privilege :- Minimum access given.

Helps prevent Attacks.

## (Question no. 6)

Given :- $a = 43$ , $g = 17$

a) Public key of A :-

$A = 17^9 \bmod 43$

$A = 41$

b) Public key of B :-

$B = 17^5 \bmod 43$

$B = 40$

c) Key by Server A :-

$k_A = 40^9 \bmod 43$

$k_A = 11$

d) Key by Server B :-

$K_B = 41^5 \bmod 43$

$k_B = 11$

e) Shared Secret key :-

$K = 11$

f) Reason of Security :- Due to discrete logarithm problem. It is very difficult to solve.

g) Vulnerable Attack :-

**MITM attack :-**

- Attacker intercepts communication
- Creates fake keys
- Controls data.

# Comsats University Islamabad

# Wah Campus

# Assignment no 2

| **Course Title:** | Introduction to Cyber Security | **Course Code** | CYC205 | Credit Hours: | 3(2,1) |
|---|---|---|---|---|---|
| **Instructor:** | Lecturer Mr. Salman Khan | **Program Name:** | BS Computer Science | | |
| **Deadline:** | 25-March-2026 | **Credit Points:** | ------- | | |

**Instructions:**

- Assignment must be handWritten.
- If caught copying, you will receive an **'F' grade**.
- Write your full **name and registration number** clearly on the front page.
- Please try to answer all questions – do not leave any blank.
- Manage your time wisely – and submit the assignment on time.
- Must have a Proper Title Page
- Use A4 Sheets For Assignment

**Question 1**

A new cybersecurity analyst is confused about how security measures map to the OSI model.

a) Explain how firewalls, encryption, and intrusion detection systems (IDS) map to specific layers of the OSI model.

b) Analyze how a **Zero-Day Attack** can exploit vulnerabilities across different OSI layers and explain the associated risks.

**Question 2**

a) Compare and contrast **SYN scan** and **UDP scan** as port scanning techniques. Explain their technical mechanisms and why they differ based on the **difference between TCP and UDP**.

b) Describe the concept of a **Man-in-the-Middle (MitM)** attack. Choose **one type** of MitM attack (e.g., ARP Spoofing) and explain its step-by-step mechanism.

**Question 3**

a) Distinguish between **Privilege Escalation** and **Insider Threats**. For each of the three types of insider threats (malicious, negligent, compromised), construct a brief realistic scenario that could lead to a data breach.

b) Explain the fundamental principle behind **SQL Injection attacks**. Why is **Inferential (Blind) SQL Injection** more difficult to detect and exploit than classic SQL injection?

**Question 4**

Using the **Infrastructure Security** layers as your framework:

a) For **Security Layer-1: Perimeter Defense**, discuss one major limitation of a traditional firewall in modern cloud environments.

b) For **Security Layer-3: Host Protection**, compare traditional antivirus software with modern Endpoint Detection and Response (EDR) solutions. How do their approaches to threat detection differ?

c) For **Security Layer-4: Data Protection**, analyze **encryption** and **tokenization** as data protection methods. For each, describe one specific use case where it would be the most appropriate choice.

**Question 5**

A company is migrating to the cloud and considering IaaS, PaaS, and SaaS models.

a) Briefly define each of the three cloud service models.

b) Choose **one** cloud model and analyze the most significant security threats associated with it. Consider the Shared Responsibility Model in your answer.

c) Explain how **Identity and Access Management (IAM)** principles, such as multi-factor authentication and the principle of least privilege, help mitigate threats in cloud environments.

**Question 6**

**Applied Cryptography: Diffie-Hellman Key Exchange**

**Scenario:**
Two servers, Server A and Server B, need to establish a shared secret key over an insecure network using the Diffie-Hellman protocol.

**(Numerical Problem)**
They agree to use the prime number p = 43 and the base g = 17. These values are public.

a) Server A chooses a private key a = 9. Calculate its public key A. (A = g^a mod p)

b) Server B chooses a private key b = 5. Calculate its public key B. (B = g^b mod p)

c) Show how Server A computes the shared secret key k using Server B's public key. (k = B^a mod p)

d) Show how Server B computes the shared secret key k using Server A's public key. (k = A^b mod p)

**(Conceptual Analysis)**

e) What is the numerical value of the shared secret key k that both servers establish?

f) Explain why an eavesdropper cannot easily determine k even if they capture p=43, g=17, A, and B. What mathematical problem are they trying to solve?

g) Name the active attack to which this basic Diffie-Hellman exchange is vulnerable and briefly explain how it works.